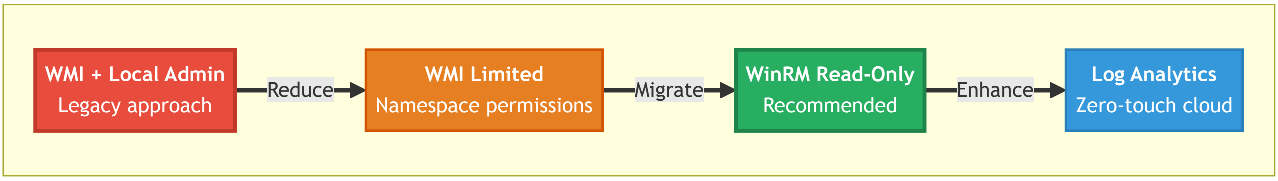
Route to Least Privilege

OmniGaze Scanning Methods - Security Journey

This document outlines the progressive journey from high-privilege scanning to minimal-privilege observability, enabling organizations to achieve comprehensive infrastructure visibility while minimizing security exposure.

The Privilege Spectrum

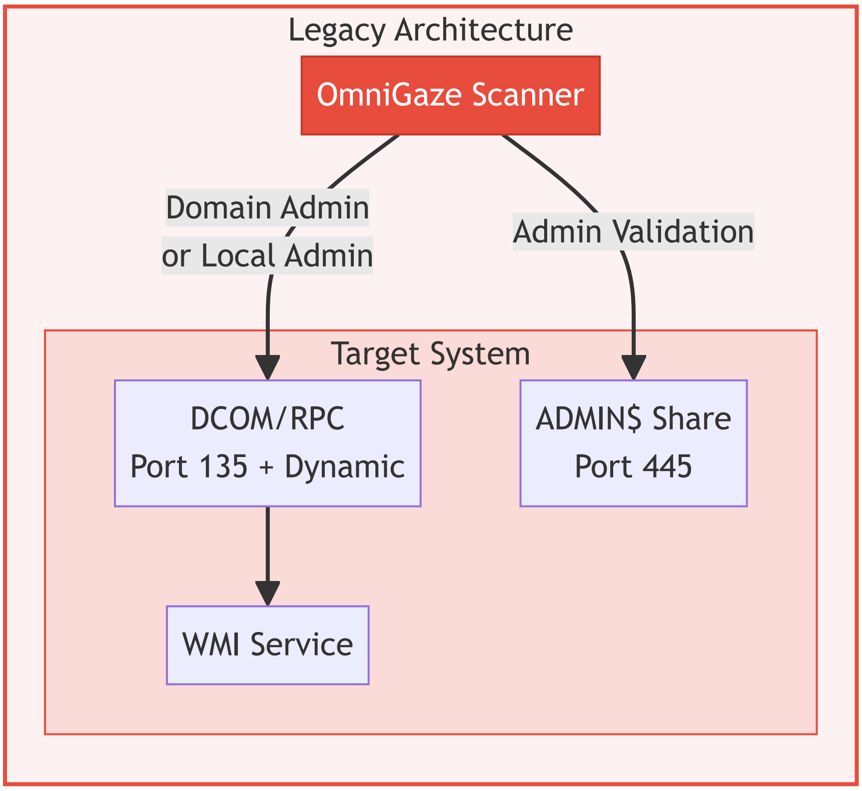


> **Key Insight**: With proper permissions, WinRM provides access to **Event Logs**, **Cluster Info**, and even **IIS Configuration** without local admin. WinRM delivers **100% of required data** with the right setup.

---

1. WMI with Local Admin Access

> **Status: LEGACY** - Not recommended for new deployments



Why Move Away?

Risk	Impact
Credential exposure	Admin credentials stored/transmitted
Lateral movement	Compromised creds = full network access
Firewall complexity	Multiple dynamic ports required
Audit concerns	Admin access triggers security alerts

What Actually Requires Admin?

Feature	WMI Admin	WinRM Non-Admin	Notes
Core System Info	Yes	**Yes**	Always available
Network Configuration	Yes	**Yes**	Always available
Running Processes	Yes	**Yes**	Always available
Installed Software	Yes	**Yes**	Always available

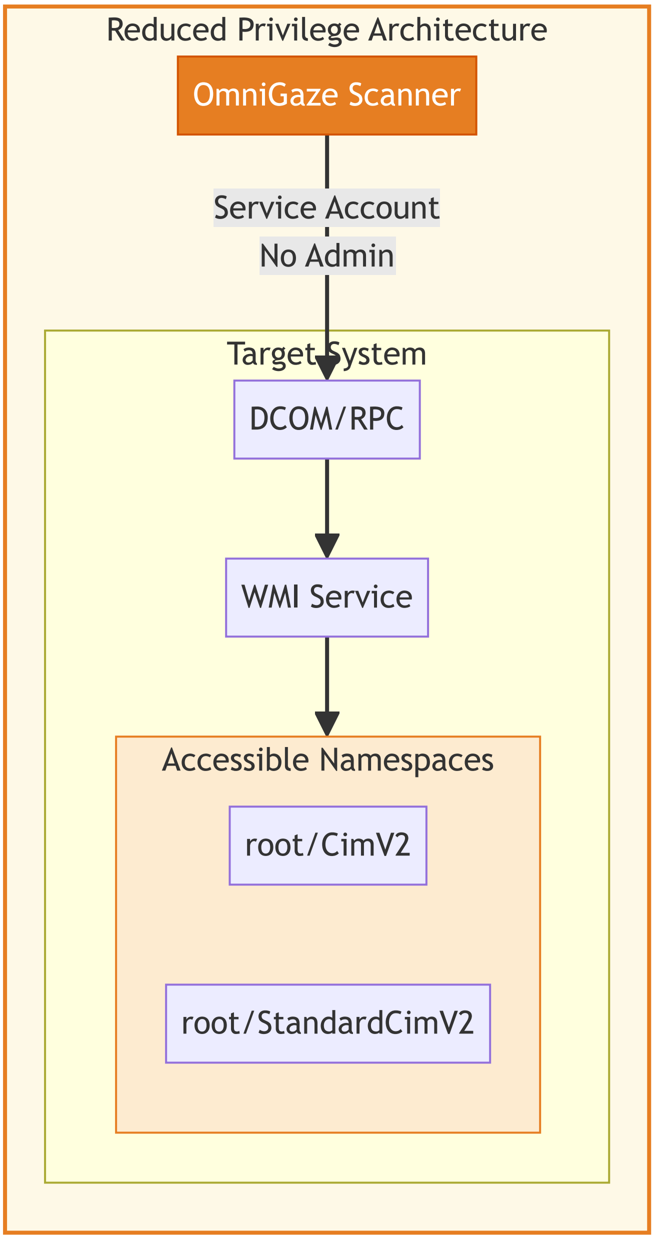
Storage/Volumes	Yes	**Yes**	Always available
Process Owners	Yes	**Yes**	Via Get-Process
Event Logs	Yes	**Yes**	Event Log Readers group
Cluster Info	Yes	**Yes**	Cluster Read-Only access
IIS Configuration	Yes	**Yes**	Config file read (see below)

Reality: WinRM non-admin provides **100% of capabilities** with proper permissions.

---

2. WMI without Local Admin

> **Status: TRANSITIONAL** - Stepping stone to WinRM



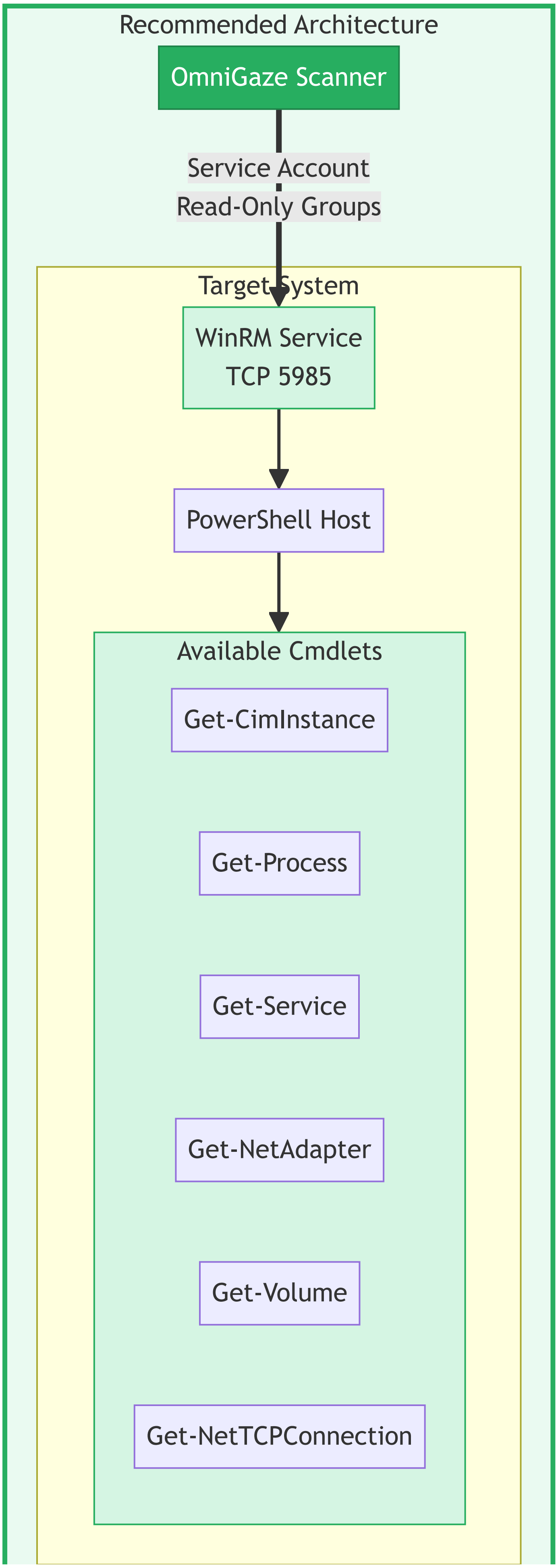
Limitations

- Still requires DCOM/RPC firewall rules
- Complex WMI namespace permission setup
- No Event Log Readers capability
- Protocol overhead higher than WinRM

---

3. WinRM with Read-Only Access

> **Status: RECOMMENDED** - Best balance of capability and security


Recommended Architecture
OmniGaze Scanner
Service Account
Read-Only Groups
Target System
WinRM Service
TCP 5985
PowerShell Host
Available Cmdlets
Get-CimInstance
Get-Process
Get-Service
Get-NetAdapter
Get-Volume
Get-NetTCPConnection

One-Command Setup

OmniGaze provides an automated setup script that configures everything:

```
# Single command - handles all configuration automatically
.\Setup-WinRMNonAdmin.ps1 -ServiceAccount "DOMAIN\svc-omnigaze"
```

That's it. The script automatically configures:

- Group memberships (Remote Management Users, Performance Monitor Users, **Event Log Readers**, etc.)
- WinRM service permissions (SDDL)
- WMI namespace access
- Firewall rules (TCP 5985)
- Local account token filter (if needed)

For **Cluster access**, run on each cluster node:

```
Grant-ClusterAccess -User "DOMAIN\svc-omnigaze" -ReadOnly
```

IIS Configuration Without Admin

There are multiple ways to access IIS configuration without local admin privileges:

Method	Setup Complexity	Security	Best For
Config File Read	Low	Medium	Read-only inventory
WMI IIS Provider	Medium	Good	Legacy compatibility
JEA Endpoint	High	Excellent	Full cmdlet access

Recommended: Direct Config File Read

Grant NTFS Read permission to the service account on the IIS config folder:

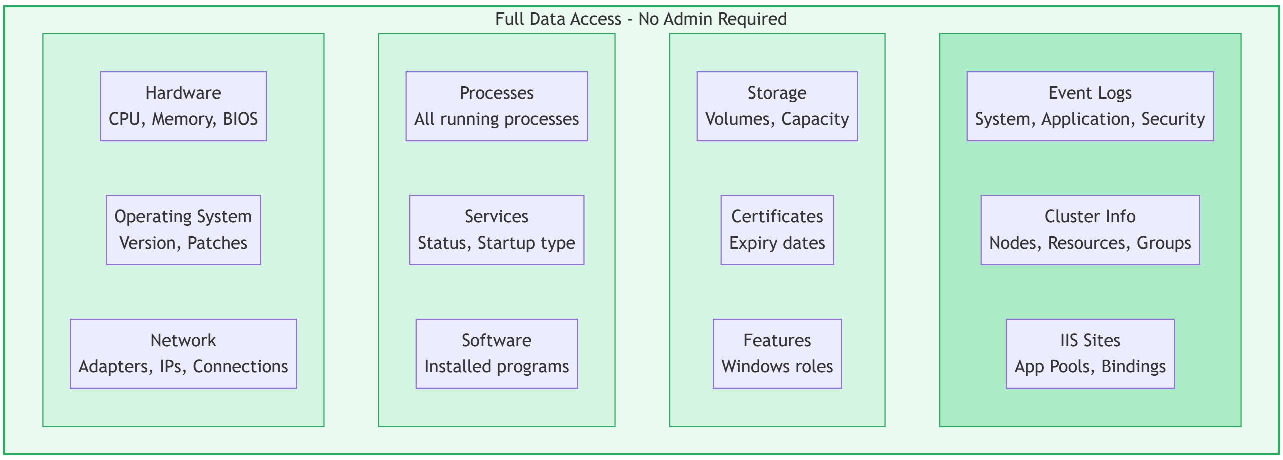
```
# One-time setup on IIS servers
$configPath = "$env:windir\system32\inetsrv\config"
$acl = Get-Acl $configPath
$rule = New-Object System.Security.AccessControl.FileSystemAccessRule(
```

```
    "DOMAIN\svc-omnigaze", "Read", "ContainerInherit,ObjectInherit", "None", "Allow"
$acl.AddAccessRule($rule)
Set-Acl $configPath $acl
```

This allows reading `applicationHost.config` which contains all IIS sites, app pools, and bindings. OmniGaze can parse this XML file directly without requiring IIS PowerShell cmdlets.

> **Note**: This grants read access to all IIS configuration. For environments requiring stricter isolation, use the JEA approach instead.

What You Get Without Admin



Firewall: Single Port

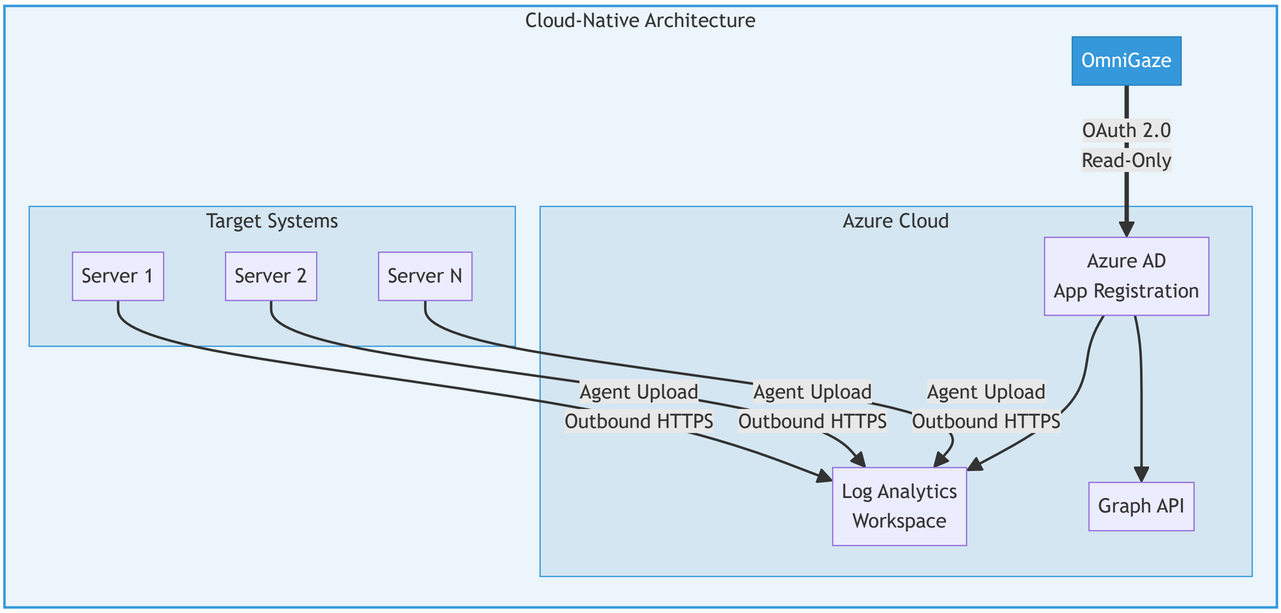
```
TCP 5985 (HTTP) or TCP 5986 (HTTPS)
```

Compare to WMI: Port 135 + dynamic range 49152-65535

---

4. Log Analytics / Azure Graph API

> **Status: CLOUD-NATIVE** - Zero-touch passive scanning



Zero Credentials on Target Systems

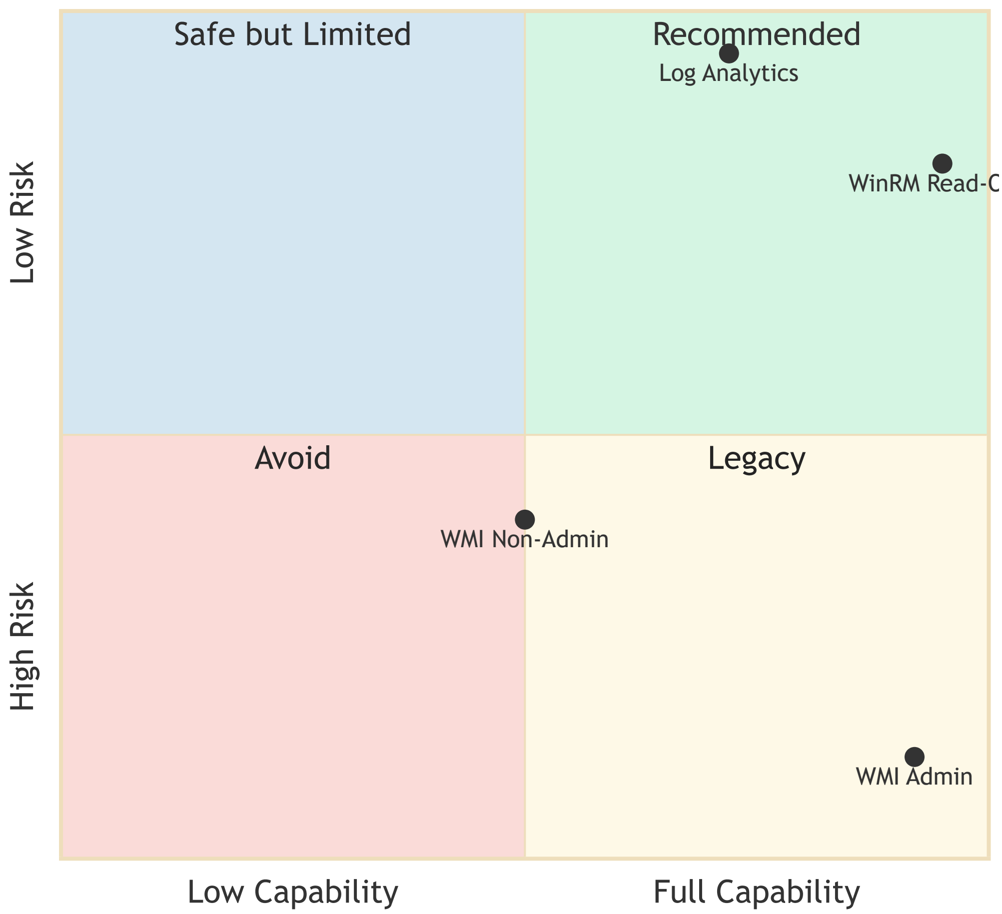
Traditional	Cloud-Native
Deploy credentials to targets	No credentials needed
Open firewall ports inbound	Agents use outbound HTTPS only
Maintain service accounts	Azure AD app registration
Credential rotation burden	Token-based authentication

Best For

- Global enterprises with Azure/M365
- Environments where agents are already deployed
- Historical data analysis (up to 70,000 days retention)
- Hybrid cloud infrastructure

Comparison Matrix

Scanning Method Evaluation



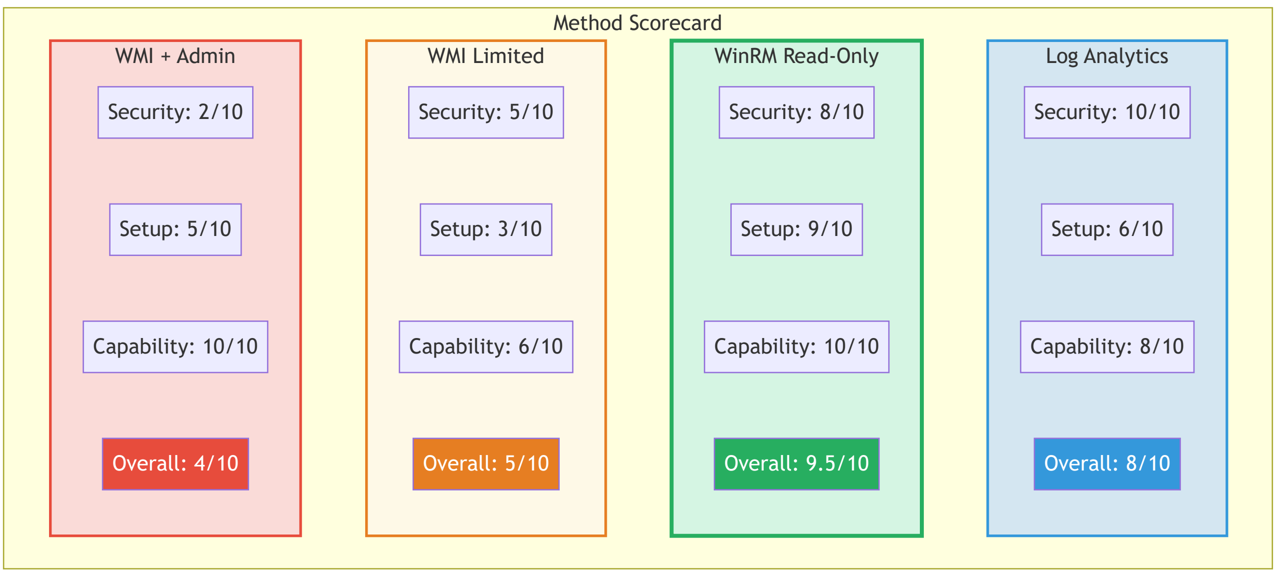
Detailed Feature Comparison

Category	Feature	WMI Admin	WMI Limited	WinRM	Log Analytics
Security	Local Admin Required	Yes	No	No	No
	Credentials on Target	Yes	Yes	Yes	**No**
	Attack Surface	High	Medium	**Low**	**Minimal**
	Audit Compliance	Poor	Fair	**Good**	**Excellent**
Setup	Complexity	Medium	High	**Low**	Medium
	Automation	Manual	Manual	**Script**	Portal
	Firewall Ports	Many	Many	**One**	**None**

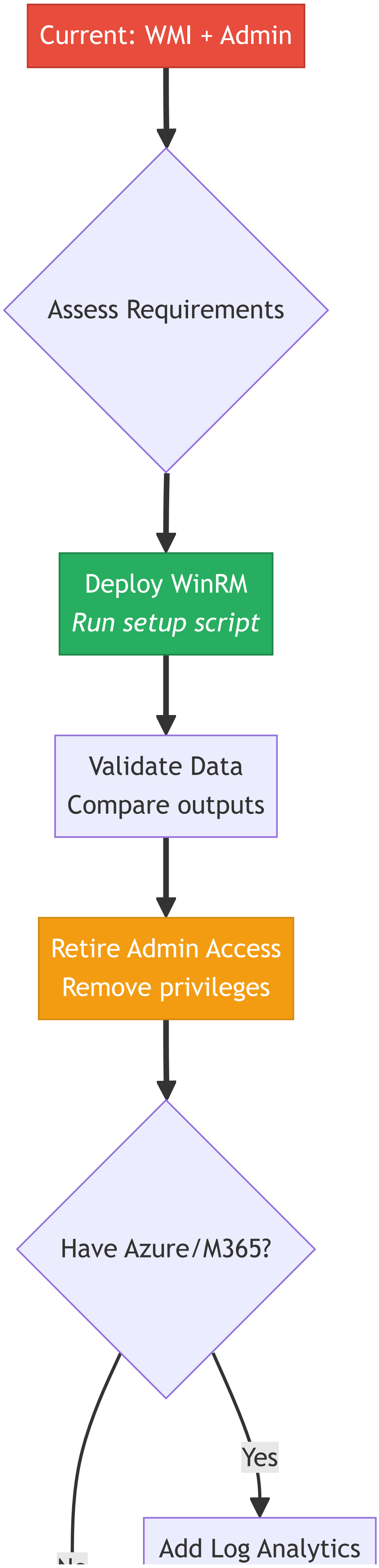
	Time to Deploy	Hours	Hours	**Minutes**	Hours
Capability	Hardware Inventory	Full	Full	**Full**	Full
	Process Data	Full	Limited	**Full**	Full
	Network Connections	Full	Full	**Full**	Full
	Installed Software	Full	Full	**Full**	Full
	Services	Full	Full	**Full**	Full
	Event Logs	Full	No	**Full***	Yes
	Cluster Info	Full	No	**Full***	Partial
	IIS Configuration	Full	No	**Full***	No
Operations	Scalability	10K	10K	**50K+**	**Unlimited**
	Historical Data	No	No	No	**Yes**
	Real-time Queries	Yes	Yes	**Yes**	Near-RT

*Event Log Readers group + Cluster Read-Only access + IIS config file read permission (simple setup)

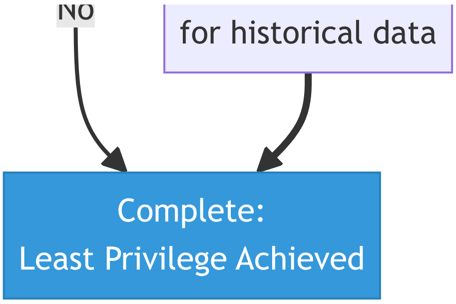
Visual Scorecard



Migration Path



Current: WMI + Admin
Assess Requirements
Deploy WinRM
Run setup script
Validate Data
Compare outputs
Retire Admin Access
Remove privileges
Have Azure/M365?
Yes
Add Log Analytics

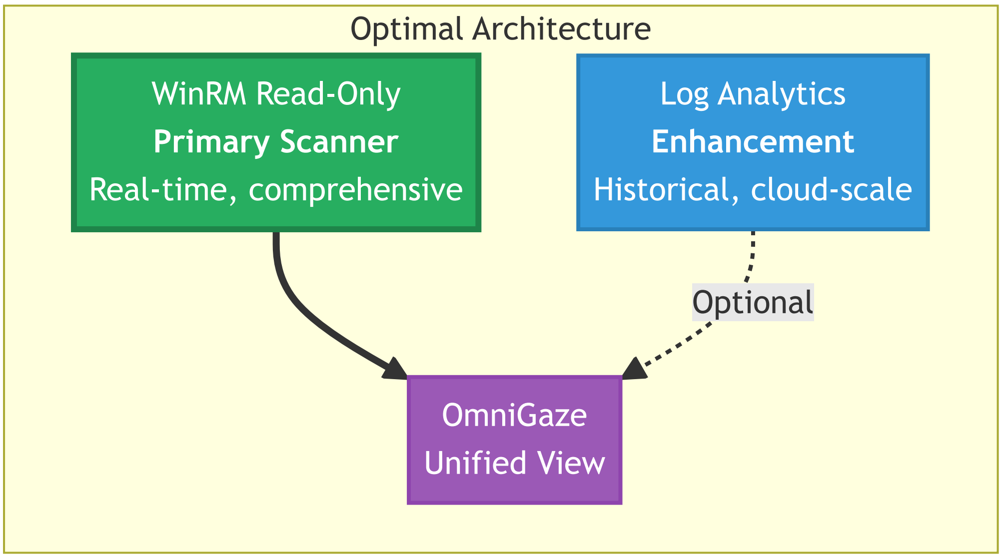


Quick Start: WinRM Migration

```
# Step 1: Deploy to target systems (via GPO, SCCM, or manually)
.\Setup-WinRMNonAdmin.ps1 -ServiceAccount "DOMAIN\svc-omnigaze"

# Step 2: Update OmniGaze credentials to use service account
# Step 3: Run scan - WinRM is auto-selected when available
# Step 4: Verify data completeness
# Step 5: Remove old admin access
```

Recommendation



For most organizations:

1. **Start with WinRM** - One script, full capability, no admin required
2. **Add Log Analytics** - If you need historical data or have Azure/M365
3. **Never use admin access** - The negligible features don't justify the risk

---

Summary

Method	When to Use	Setup Time	Limitations
WMI + Admin	**Never** (legacy only)	-	Security risk
WMI Limited	Transitional step	Hours	No Event Logs/Cluster/IIS
WinRM Read-Only	**Default choice**	**Minutes**	**None**
Log Analytics	Cloud enhancement	Hours	Requires Azure

Bottom Line: WinRM with read-only access provides **100% of scanning capability** (including Event Logs, Cluster Info, and IIS) with minimal security exposure and a single-command setup.

References

Event Log Access

- Event Log Rights for Non-Administrators - Event Log Readers group configuration
- How to collect remote windows logs as non-admin - Remote event log permissions
- Security Log access for non-admin - Security log registry permissions

Cluster Access

- PowerShell for Failover Clustering: Read-Only Cluster Access - Microsoft official documentation
- Grant Users Limited or Full Access to Windows Failover Clusters - Grant-ClusterAccess usage
- Get-ClusterAccess cmdlet - Microsoft Learn

IIS Configuration

- Manage IIS as a non admin user - JEA approach for IIS
- Configuring Remote Administration and Feature Delegation - Microsoft Learn

- Web Deploy non-admin permissions - Config folder access
- IIS WMI Provider queries - Alternative WMI approach